黑云压城-云端服务滥用攻击剖析

绿盟科技 · 高 东

2021首届-西部云安全峰会
Western China Cloud Security Summit 2021
腾讯安全 | 腾讯安全云鼎实验室 | 陕西省计算机学会

About Me

高 东

绿盟科技天元实验室主管研究员，M01N战队负责人，技术经理

专注于高级威胁模拟与对抗，蓝军实战化攻击与对抗技术研究

技术发展

- 新领域技术
- 新的业务形态
- 新的安全机制
- 新的安全产品

攻击形态

- **攻击技术：**达成阶段性战术目的所使用的攻击性技术
- **对抗技术：**保证攻击能正常实施而采用的对抗性技术

攻击特征

“滥用”

“黑云压城城欲摧”

云服务能力 → 滥用 / 武器化 → **云打击能力**

- 云原生能力
- 公有云管理
- 基础设施即服务（IaaS）
- 容器即服务（CaaS）
- 函数即服务（FaaS）
- 云应用服务
- ……

- 域前置
- Socks/ToH 代理
- C2 服务器
- 钓鱼网站
- 栽荷投递
- 数据回传
- ……

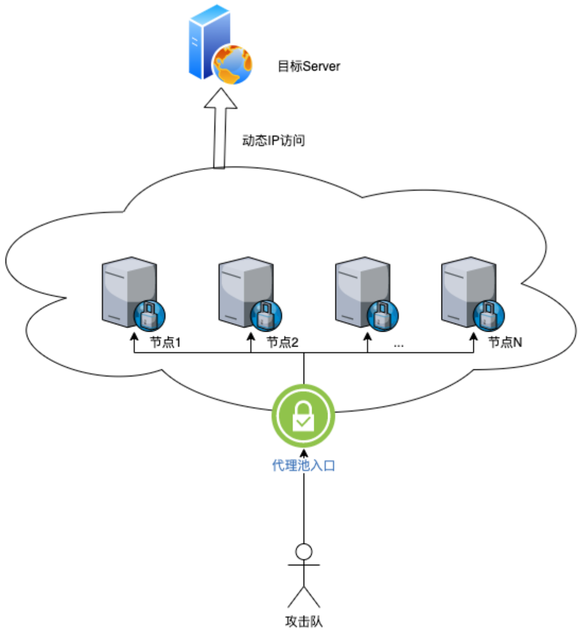
拨号VPS搭建动态代理池

背景

- 防守队封IP，IP资源紧缺
- 使用自己热点IP容易被防守方定位
- 手动切换代理IP繁索，效率低
- 部分工具不支持攻击过程中切换IP

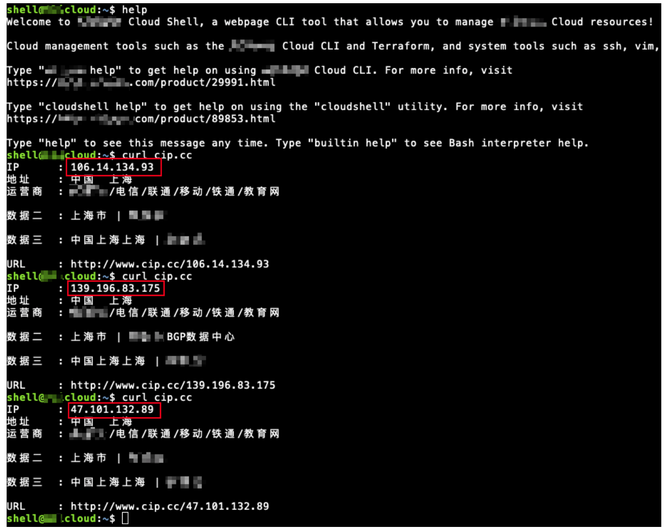
特点

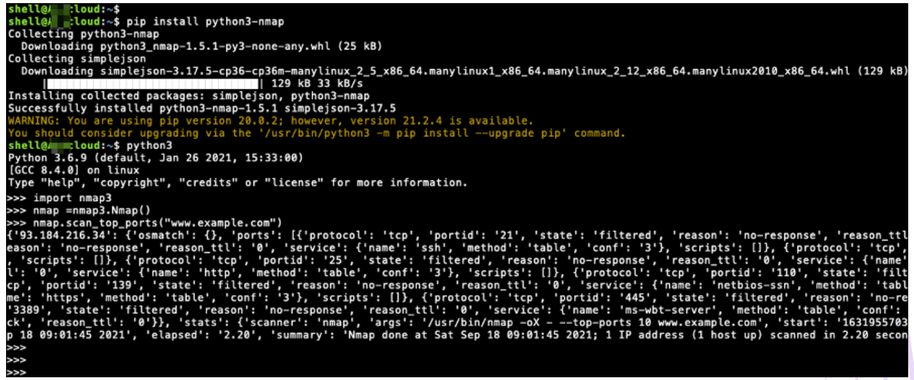
- 统一入口，多个出口地区（山东、湖北、浙江…）
- IP资源丰富， 10个A段公网IP资源，每分钟节点更换IP
- 系统可扩展强，扩容操作一条命令完成
- 系统可靠稳定



滥用公有云 Cloud Shell

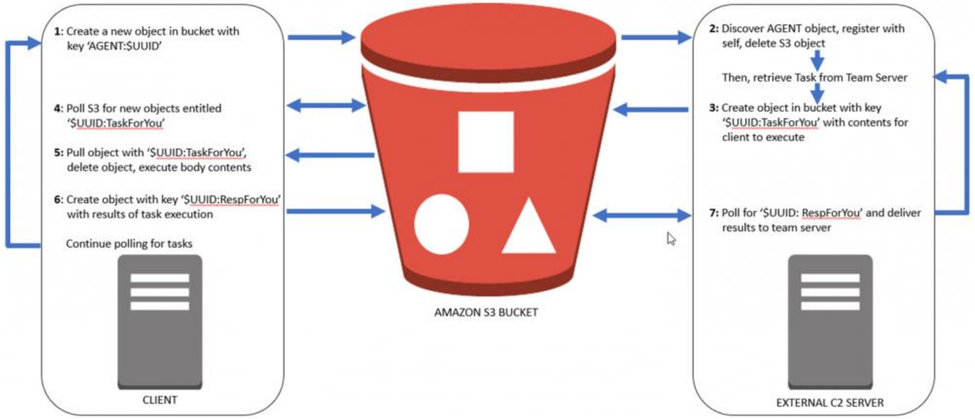
- 云命令行（Cloud Shell）是一种通过浏览器访问的用于管理云上资源的交互式shell
- 在云命令行启动时会创建一台 Linux 虚拟机，免费独享使用。当会话处于活跃状态时，实例长期有效
- 网络出口多，可被滥用于扫描、探测、代理等多种攻击





滥用对象存储及API进行C2控制

- AWS API 使用 Boto 库在 python 中可轻松简洁地实现。
- 域名可信度高，通信隐蔽性强
- 如果开发人员和 DevOps 团队都使用 AWS 自动化基础设施和备份，来自AWS S3的流量将融入常规工作流
- 使用AWS S3 对象作唯一标识代理并传输任意长度和内容的数据
- 采用轮询、推送和拉取的方式，效率较低，能处理的控制指令有限



https://github.com/RhinoSecurityLabs/external_c2_framework

Cloud Functions滥用

购买成本低

- 一定规模内相较于云服务器费用更低，且各大云厂商提供免费的Serverless套餐
- 按需使用，按量付费，降低攻击者成本

部署成本低

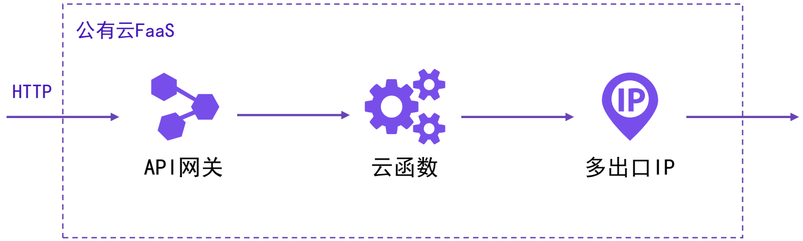
- 用户只需实现函数的核心逻辑，而无须关心函数的部署及执行
- 高效实现单一场景的攻击利用，编写简单并能省去部署的成本

部署灵活

- Serverless工作流（Serverless Workflow）可用来编排调度函数执行，协调分布式任务
- 灵活编排实现复杂攻击流程和逻辑

访问域名可信

- 通过API网关等触发器去触发函数的执行，云厂商会提供一个可信的子域名
- 域名可信度高，攻击流量被审计风险降低



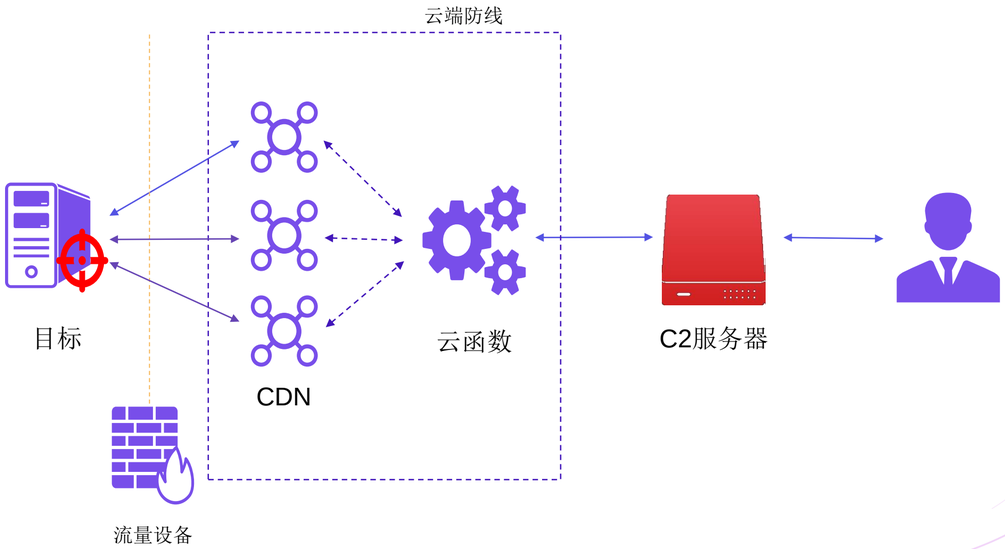
滥用FaaS作为代理或C2前置转发器

反制措施

拒绝钱包攻击（Denial of Wallet，DoW）是一种以类似于拒绝服务（DoS）攻击的方式运行，向Serverless服务发起大量请求触发执行以强制财务消耗为目的的攻击。

CDN + FaaS打造攻击前置

- 两次转发保护，多重隐蔽性
- 存在绕过厂商限制添加域前置的可能性
- 避免C2请求地址是函数地址，过滤请求header头中带有的云函数特征
- 对非C2流量及潜在攻击流量进行过滤（例如针对云函数服务的DOS攻击）
- 在CDN上定义响应状态码跳转进行基础设施保护
- 特殊路径可通过CDN和其他服务结合的方式进行请求分发跳转，增强基础设施在伪装性、探测监控及溯源反制等方面的能力



CDN + FaaS

可扩展的云原生蓝军基础设施

绵亘正面

- 多攻击出口
- 多阶段（stager）
- 稳定可用
- 不被破坏
- 可控制潜伏触发
- 动态可控
- ……

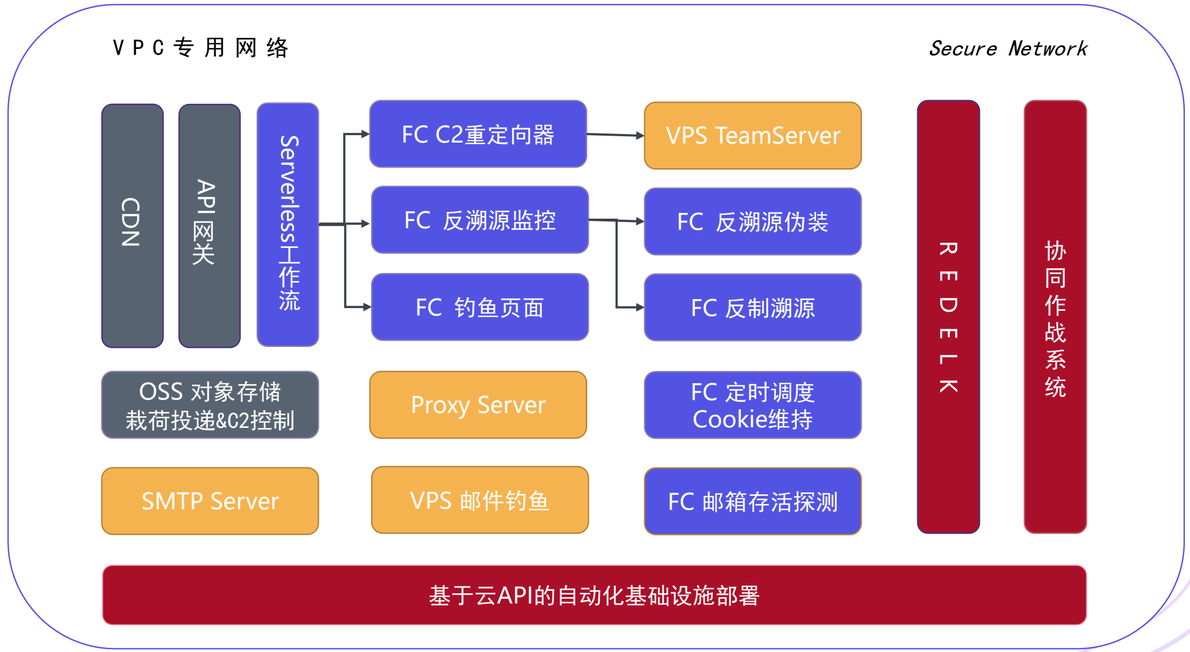
纵深深远

- 攻击流量隐匿、伪装
- C2保护
- 不被溯源
- 可反溯源监控
- 可防溯源伪装
- 可反制溯源
- ……

弹性可扩展

- 灵活实现攻击功能
- 流程可编排
- 自动化部署
- 可审计可复盘
- 可支撑协同作战
- ……

“满足OPSEC要求的基础上可灵活支持多战术状态”



蓝军云上基础设施模型

云服务应用

- 云存储、云盘、图床
- 云文档、云笔记、在线协作
- Pastebin提供文本存储服务
- 代码托管平台
- 在线社交平台
- 在线翻译平台
- ……

滥用

- C2控制
- C2开关
- 栽荷投递
- 数据渗出
- 钓鱼攻击
- ……

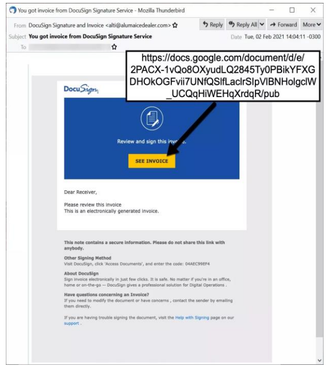
特点

- 可信度高
- 隐蔽性强
- 灵活高效
- 溯源难度大
- 攻击成本低
- 传播性强
- ……

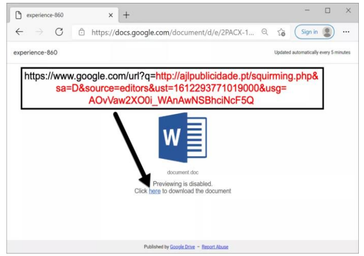
Hancitor利用云文档进行邮件钓鱼

- 邮件无恶意链接和附件，使用云文档链接增强可信度并规避邮件安全网关的审查
- 滥用云文档在线预览功能，诱导受害者访问恶意网站
- 利用HTTP Smuggling技术在受害者浏览器动态生成钓鱼文档，有效规避防火墙、全流量分析设备和沙箱的监测
- 文档下载的同时，页面重定向到DocuSign官网网站，增强了文档来源的可信度

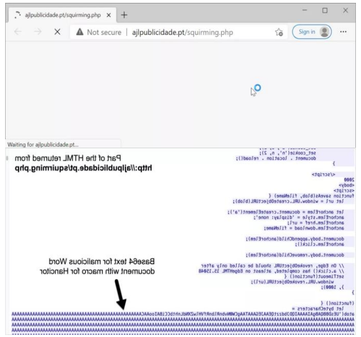
伪造数字签名提供商DocSign身份投递含有云文档链接的邮件



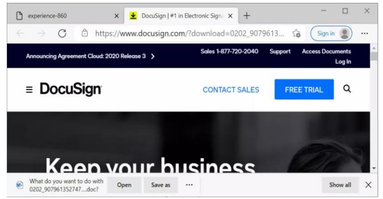
云文档预览内容被设计为该文档下载页面，诱导目标点击链接



页面跳转到托管恶意文档的网站，使用HTML Smuggling投递恶意文档



恶意文档投递完成，页面同时重定向到DocuSign官网



Molerats组织滥用云服务的攻击活动

- 使用Dropbox进行文件下载和上传，并使用Facebook / Simplenote帖子来传递来自攻击者的C2命令
- 域名可信度高，通信隐蔽性强
- 采用轮询、推送和拉取的方式，效率较低，能处理的控制指令有限

从Facebook帖子或Simplenote中获取Dropbox令牌，攻击者可编辑帖子更改令牌

将本地信息收集到的敏感信息打包回传至Dropbox

在Facebook帖子中获取执行指令，包括系统命令、shellcode名称、睡眠时间等

下载并执行从Dropbox上存储的shellcode或其他恶意文件

云厂商防护策略

Prevention

- 账户认证：实名认证，信用卡背景调查，2FA
- 流量监测：对租户环境内外进行恶意流量监控
- 防火墙和软件更新：云供应商可强制要求防火墙，鼓励用户VM安全更新
- 权限管理： 加强权限管理和边界管理，部分服务按需求提供受限模式
- 内容监管：基于情报体系，对于恶意链接强制设置不可点击

Detection

- 主动取证：云厂商可部署自动化、周期性的随机取证分析虚拟磁盘（VHD），鉴别可疑账户等等
- 异常探测：通过流量、日志等实时监测可疑行为
- 行为审计：Serverless静态、动态安全审计、监测恶意行为

Recovery

- 应急体系：当检测到异常滥用情况，清理滥用的功能并且恢复系统状态
- 网络管理策略：封堵流量
- VM分离：取证
- 黑名单管理：精准侦测有恶意行为的账户，并进行黑名单封堵

防守方防护策略

- 黑白名单机制，审计公有云平台及云服务通信流量
- 限制非浏览器、非APP的网络访问云服务
- 证书交换频率
- 大数据威胁狩猎
- 终端层安全防护

感谢聆听

Thanks

2021首届-西部云安全峰会

Western China Cloud Security Summit 2021